Skript: Passwortsicherheit & Phishing

Kantonsschule im Lee

Thema: Passwortsicherheit, Phishing, Entropie & Best Practices

Fach: Informatik

Autor: Laurin Ott

Datum: 31. Oktober 2026

Inhaltsverzeichnis

1 Passwortsicherheit **2**
- 1.1 Einleitung . . . 2
- 1.2 Grundlegende Begriffe und Angriffsarten . . . 2
- 1.3 Mathematische Grundlage: Die Passwort-Entropie . . . 2
  - 1.3.1 Beispielrechnung . . . 3
  - 1.3.2 Fazit der Berechnung . . . 3
- 1.4 Aktuelle Richtlinien und Best Practices . . . 4

2 Phishing **5**
- 2.1 Einleitung . . . 5
- 2.2 Grundlegende Begriffe und Angriffsarten . . . 5
- 2.3 Psychologische Faktoren und Wirkungsweise . . . 5
- 2.4 Aktuelle Richtlinien und Best Practices . . . 6

3 Übungsaufgaben **7**
- 3.1 Aufgabenblatt 1: Passwortsicherheit . . . 7
  - 3.1.1 Teil 1: Begriffsdefinitionen & Grundlagen . . . 7
  - 3.1.2 Teil 2: Mathematische Berechnungen (Entropie) . . . 7
  - 3.1.3 Teil 3: Anwendung & Best Practices . . . 8
- 3.2 Aufgabenblatt 2: Phishing, Social Engineering & Best Practices . . . 9
  - 3.2.1 Teil 1: Verständnis & Begriffe . . . 9
  - 3.2.2 Teil 2: Psychologische Faktoren & Szenario-Analyse . . . 10
  - 3.2.3 Teil 3: Anwendung & Best Practices (Richtlinien beurteilen) . . . 11

Literaturverzeichnis **12**

Akronyme **12**

Glossar **13**

1 Passwortsicherheit

1.1 Einleitung

In fast allen IT-Systemen bilden Passwörter die erste Hürde gegen unbefugten Zugriff. In der Praxis zeigt sich jedoch immer wieder, dass schwache, kompromittierte oder mehrfach genutzte Passwörter eine der grössten Sicherheitslücken darstellen. Dieses Skript gibt einen Überblick über die mathematischen Grundlagen der Passwort-Stärke und fasst die aktuellen Empfehlungen zur Absicherung digitaler Identitäten zusammen [2].

1.2 Grundlegende Begriffe und Angriffsarten

In der Authentisierung und Passwort-Sicherheit spielen verschiedene Konzepte und Bedrohungen eine entscheidende Rolle.

Neben dem rein mathematischen Brute-Force-Angriff nutzen Angreifer in der Praxis sehr häufig einen Dictionary Attack (Wörterbuchangriff), bei dem gezielt Listen mit geläufigen Wörtern, Namen und bekannten Daten durchprobiert werden. Um diesen Methoden zu entgehen, ist eine hohe Entropie entscheidend. Zusätzlich schützt moderne Multi-Faktor-Authentisierung (MFA) (z. B. eine Bestätigung direkt auf dem Smartphone) effektiv vor unbefugtem Zugriff.

1.3 Mathematische Grundlage: Die Passwort-Entropie

Die Stärke eines Passworts gegenüber automatisierten Angriffen lässt sich mathematisch über die Shannon-Entropie (E) beschreiben. Sie beschreibt den Grad der Zufälligkeit bei der Erstellung eines Passworts und wird in der Einheit Bit angegeben. Ein Bit entspricht dabei einer binären Entscheidung (Ja/Nein), die ein Computer benötigt, um den möglichen Suchraum Schritt für Schritt einzuschränken. Unter der Bedingung, dass alle Zeichen völlig zufällig und unabhängig voneinander gewählt werden (wie bei der Generierung durch einen Passwort-Manager), berechnet sich die Entropie wie folgt:

$$N = R^L$$

$$E = \log_2(N) = \log_2(R^L) = L \cdot \log_2(R)$$

Für Passphrasen gilt die Formel:

$$N = W^L$$

$$E = \log_2(N) = \log_2(W^L) = L \cdot \log_2(W)$$

- N: Anzahl der möglichen Zeichen Kombinationen für das Passwort oder Wörter Kombinationen für die Passphrase (Suchraum).
- E: Entropie in Bit (Mass für die Stärke des Passworts).
- L: Die Länge des Passworts (Anzahl der verwendeten Zeichen) oder die Länge der Passphrase (Anzahl der verwendeten Wörter).
- R: Die Grösse des verfügbaren Zeichensatzes (z. B. Kleinbuchstaben, Grossbuchstaben, Zahlen, Sonderzeichen).
- W: Die Anzahl der Wörter in dem Wörterbuch.

Wichtig ist, dass diese Formel echte Zufallsauswahl voraus setzt. Selbst gewählte Passwörter (wie z. B. Sommer2026!) besitzen eine deutlich geringere Entropie, da menschliche Eingaben meist vorhersehbaren Mustern folgen und dadurch der tatsächliche Suchraum für Angreifer stark schrumpft. Das Gleiche gilt für Passphrasen, Passphrasen sind mehrere zufällige Wörter, die zu einer langen Wörterkette kombiniert werden.

1.3.1 Beispielrechnung

- **8 Zeichen (nur Kleinbuchstaben):** Bei $L = 8$ und einem Zeichensatz von $R = 26$ ergibt sich eine Entropie von:

$$E_8 = 8 \cdot \log_2(26) \approx 37{,}6 \text{ Bit}$$

- **Verdopplung auf 16 Zeichen (gleicher Zeichensatz):** Bei $L = 16$ und $R = 26$ steigt die Entropie linear mit der Länge auf:

$$E_{16} = 16 \cdot \log_2(26) \approx 75{,}2 \text{ Bit}$$

In Tabelle 1 sind die Entropie-Werte für verschiedene Passwort-Längen und Zeichensätze zusammenfassend dargestellt.

Zeichensatz (R)	**Länge** (L)	**Formel**	**Entropie** (E)
Kleinbuchstaben ($R = 26$)	8	$8 \cdot \log_2(26)$	$\approx 37{,}6$ Bit
Kleinbuchstaben ($R = 26$)	16	$16 \cdot \log_2(26)$	$\approx 75{,}2$ Bit
Alle Zeichen ($R = 94$)	8	$8 \cdot \log_2(94)$	$\approx 52{,}4$ Bit
Kleinbuchstaben ($R = 26$)	20	$20 \cdot \log_2(26)$	$\approx 94{,}0$ Bit
Alle Buchstaben ($R = 52$)	20	$20 \cdot \log_2(52)$	$\approx 114{,}0$ Bit
Alle Buchstaben + Zahlen ($R = 62$)	20	$20 \cdot \log_2(62)$	$\approx 119{,}1$ Bit
Alle Zeichen ($R = 94$)	20	$20 \cdot \log_2(94)$	$\approx 131{,}1$ Bit

Tabelle 1: Vergleich der Passwort-Entropie für verschiedene Längen und Zeichensätze.

1.3.2 Fazit der Berechnung

Weil die Anzahl der möglichen Kombinationen ($N = R^L$) exponentiell mit der Länge (L) wächst, erhöht jedes zusätzliche Zeichen die Sicherheit drastisch. Die Entropie ($E = L \cdot \log_2(R)$) wächst zwar linear mit der Länge und nur logarithmisch mit der Zeichensatzauswahl (R). Für die Praxis bedeutet das aber, ein längeres Passwort bietet um ein Vielfaches mehr Schutz als das krampfhafte Einfügen von Sonderzeichen in ein zu kurzes Passwort. Zudem schützt eine ausreichende Länge in Kombination mit Zufall effektiv vor Dictionary Attack (Wörterbuchangriff)s.

1.4 Aktuelle Richtlinien und Best Practices

Moderne Richtlinien haben sich von alten Regeln verabschiedet. Heute gelten folgende Hauptempfehlungen:

1. **Länge vor Komplexität:** Bevorzugung von Passphrasen aus mehreren zufälligen Wörtern. Selbst wenn Angreifer raffinierte Wörterbuchangriffe oder Kombinationen ausprobieren, bricht ein System bei langen Passphrasen (oft auch ohne erzwungene Sonderzeichen) ein, weil die schiere Länge den Suchraum unknackbar macht (Entropie über 80 Bit).
2. **Keine wiederholte Nutzung von Passwörtern:** Jedes Konto sollte ein einzigartiges Passwort besitzen, um die Risiken bei Datenlecks zu minimieren.
3. **Vermeidung von Passwort-Änderungen ohne Anlass:** Regelmässige erzwungene Passwort-Änderungen erhöhen die Wahrscheinlichkeit, dass Nutzer schwächere Passwörter wählen oder diese aufschreiben. Nur bei Verdacht auf Kompromittierung sollte ein Passwort geändert werden.
4. **Einsatz von Passwort-Managern:** Generierung und Verwaltung einzigartigen Passwörtern.
5. **Aktivierung von MFA:** Einrichtung eines zweiten Faktors (z. B. aufs Smartphone).

2 Phishing

2.1 Einleitung

In der digitalen Welt bilden nicht nur technische Barrieren wie Passwörter die Abwehrlinie, sondern vor allem der Mensch selbst. Eines der erfolgreichsten und am häufigsten genutzten Einfallstore für Cyberkriminelle ist Phishing. Dabei wird gezielt die menschliche Psyche ausgenutzt, um an vertrauliche Daten zu gelangen oder Schadsoftware zu verbreiten [1].

2.2 Grundlegende Begriffe und Angriffsarten

Phishing gehört zu den klassischen Social Engineering-Angriffen. Statt komplexe technische Systeme direkt zu hacken, manipulieren Angreifer gezielt Personen:

- **Klassisches Phishing:** Täuschend echte E-Mails, die vorgeben, von vertrauenswürdigen Institutionen
  (wie Banken, Streaming-Diensten oder Behörden) zu stammen.
- **Spear-Phishing:** Ein gezielter Angriff (Spear-Phishing), der auf eine spezifische Person oder bestimmte Mitarbeiter zugeschnitten ist, um Vertrauen zu erwecken.
- **Vishing & Smishing:** Betrugsversuche über Telefonanrufe (*Voice* → *Vishing*) oder Kurznachrichten (*SMS* → *Smishing*).
- **Quishing:** Das Platzieren von manipulierten QR-Codes (z. B. auf Plakaten oder Parkuhren), die zu gefälschten Webseiten führen.

2.3 Psychologische Faktoren und Wirkungsweise

Im Gegensatz zu mathematischen Angriffen zielt Phishing auf menschliche Schwachstellen wie Neugier, Hilfsbereitschaft, Gier oder vor allem **Angst und Zeitdruck** ab. Typische Maschen beinhalten drohende Konsequenzen wie angebliche Kontosperrungen, dringende Rechnungen oder verpasste Gewinne, damit das Opfer unüberlegt handelt.

2.4 Aktuelle Richtlinien und Best Practices

Um sich vor Phishing-Angriffen zu schützen, gelten im Rahmen der IT-Sicherheit folgende zentrale Empfehlungen:

1. **Kritische Hürden bewahren:** Niemals unüberlegt auf Links klicken oder Anhänge von unbekannten Absendern öffnen.
2. **Absender und URLs genau prüfen:** Auf Unstimmigkeiten in E-Mail-Adressen (z. B. Buchstabendreher in Domains (Typosquatting)) achten.
3. **MFA nutzen:** MFA erhöht den Schutz deutlich, da ein gestohlenes Passwort allein nicht für eine Anmeldung ausreicht. Dennoch ist MFA kein absoluter Schutz. Bei Live-Phishing können Angreifer den Einmalcode in Echtzeit abfangen oder Nutzer durch exzessive Anfragen zur Bestätigung verleiten (Push-Overloading). Vollständigen Schutz gegen Phishing bieten erst Verfahren wie WebAuthn/FIDO2 oder physische Sicherheitsschlüssel ([2]), da diese kryptografisch an die echte Webadresse gebunden sind.
4. **Keine sensiblen Daten preisgeben:** Seriöse Institutionen fragen niemals per E-Mail, SMS oder Telefon nach Passwörtern oder PINs.
5. **Dringlichkeit und Druckmittel hinterfragen:** E-Mails, die mit unbegründeten Drohungen (z. B. sofortige Kontosperrung) oder kurzen Fristen Panik erzeugen wollen, kritisch prüfen.
6. **Sprache und Anrede analysieren:** Unpersönliche Anreden (z. B. Sehr geehrter Kunde) sowie grammatikalische Fehler, Rechtschreibfehler, fehlende Umlaute oder auffällige Formulierungen bleiben wichtige Warnsignale für Phishing-Mails. Durch den Einsatz moderner KI-Tools sind Angreifer jedoch zunehmend in der Lage, sprachlich einwandfreie Nachrichten zu erstellen. Daher gilt, das Fehlen von Sprachfehlern kein Garantiebeweis ist für die Echtheit einer Nachricht.
7. **Direktzugriffe bevorzugen:** Webseiten und Portale stets manuell über die Eingabe der bekannten Adresse im Browser aufrufen, anstatt Links aus E-Mails zu folgen.

3 Übungsaufgaben

Dieser Abschnitt enthält Vertiefungs- und Übungsaufgaben zu den Themen aus Abschnitt 1 und Abschnitt 2.

3.1 Aufgabenblatt 1: Passwortsicherheit

3.1.1 Teil 1: Begriffsdefinitionen & Grundlagen

Aufgabe 3.1.1.1: Begriffsdefinitionen

Erklären Sie kurz in Ihren eigenen Worten den Unterschied zwischen einem Brute-Force-Angriff und einem Dictionary Attack (Wörterbuchangriff).

Aufgabe 3.1.1.2: MFA

Was bedeutet die Abkürzung MFA und wie schützt sie einen Account, selbst wenn ein Angreifer das Passwort herausgefunden hat?

3.1.2 Teil 2: Mathematische Berechnungen (Entropie)

Verwenden Sie die Formel zur Berechnung der Entropie aus Abschnitt 1.3 (sehen Sie auch Tabelle 1):

$$E = L \cdot \log_2(R)$$

Aufgabe 3.1.2.1: Einfluss des Zeichensatzes (R)

Gegeben ist ein Passwort der Länge $L = 10$.

a) Berechnen Sie die Entropie E, wenn nur Kleinbuchstaben verwendet werden ($R = 26$).

b) Berechnen Sie die Entropie E, wenn Klein-, Grossbuchstaben, Zahlen und Sonderzeichen verwendet werden ($R = 94$).

Aufgabe 3.1.2.2: Länge vs. Komplexität

Betrachten Sie die folgenden beiden Passwörter:

- **Szenario A:** Ein komplexes Passwort mit 8 Zeichen ($L = 8$), das Kleinbuchstaben, Grossbuchstaben, Zahlen und Sonderzeichen nutzt ($R = 94$).
- **Szenario B:** Ein zufälliges Passwort mit 20 Zeichen ($L = 20$), das nur aus Kleinbuchstaben besteht ($R = 26$).

Aufgabe: Berechnen Sie für beide Szenarien die Entropie E. Welches Passwort bietet eine höhere Entropie und warum entspricht dies der Regel Länge vor Komplexität?

3.1.3 Teil 3: Anwendung & Best Practices

Aufgabe 3.1.3.1: Richtlinien beurteilen

Welche der folgenden Aussagen entsprechen den aktuellen Best Practices (z. B. nach National Institute of Standards and Technology (NIST))? Begründen Sie Ihre Antwort kurz.

A) Ein sicheres Passwort muss alle 30 Tage geändert werden.

B) Passphrasen aus mehreren zufälligen Wörtern sind in der Regel sicherer und merkbarer als kurze, komplexe Zeichenketten.

C) Verwenden Sie das gleiche Passwort für mehrere Dienste, solange es sehr lang ist.

D) Der Einsatz eines Passwort-Manager wird empfohlen, um für jeden Dienst ein unikat zufälliges Passwort zu generieren.

3.2 Aufgabenblatt 2: Phishing, Social Engineering & Best Practices

3.2.1 Teil 1: Verständnis & Begriffe

Aufgabe 3.2.1.1: Begriffsdefinitionen & Abgrenzung

Erklären Sie kurz in Ihren eigenen Worten den Unterschied zwischen Klassisches Phishing und gezieltem Spear-Phishing. Gehen Sie dabei darauf ein, wer jeweils das Ziel des Angriffs ist.

Aufgabe 3.2.1.2: Gefahrenkanäle (Vishing, Smishing & Quishing)

Cyberkriminelle nutzen nicht nur E-Mails. Ordnen Sie den folgenden Angriffsformen die passende Methode zu und erklären Sie kurz, worauf man achten muss:

a) **Vishing**
b) **Smishing**
c) **Quishing**

Aufgabe 3.2.1.3: MFA

Warum ist MFA eines der effektivsten Schutzmittel gegen Phishing?
Wie schützt MFA einen Account, selbst wenn ein Opfer seine Anmeldedaten auf einer gefälschten Phishing-Website eingegeben hat?

3.2.2 Teil 2: Psychologische Faktoren & Szenario-Analyse

Aufgabe 3.2.2.1: Psychologische Tricks

Social Engineering nutzt primär menschliche Schwachstellen statt technischer Systemlücken. Nennen Sie drei psychologische Faktoren, die Angreifer gezielt ausnutzen, und beschreiben Sie kurz, wie diese einen Menschen zu unüberlegtem Handeln verleiten.

In Abbildung 1 ist eine typische verdächtige Nachricht für die nachfolgende Szenario-Analyse dargestellt.

Phishing-E-Mail-Verdachtsfall

Von: `support-service@bank-security-check.ch`
An: `max.muster@kanti.ch`
Betreff: DRINGEND: Ihr Konto wird in 2 Stunden gesperrt!

Sehr geehrter Kunde,

aufgrund verdächtiger Aktivitäten müssen Sie Ihre Daten sofort verifizieren.
Wenn Sie nicht innerhalb von 120 Minuten handeln, wird Ihr Zugang dauerhaft gesperrt.

Klicken Sie hier: `http://www.kanton-bank-login-sicherheit.com/verify`

Abbildung 1: Verdächtiges E-Mail-Fallbeispiel für die Szenario-Analyse.

Aufgabe 3.2.2.2: Fallbeispiel Szenario-Analyse

Lesen Sie die in Abbildung 1 dargestellte Nachricht aufmerksam durch.

a) Identifizieren Sie mindestens drei Merkmale in dieser Nachricht, die eindeutig auf einen Phishing-Angriff hinweisen.
b) Welche Form von Phishing und welcher psychologische Mechanismus liegen hier vor?

3.2.3 Teil 3: Anwendung & Best Practices (Richtlinien beurteilen)

Aufgabe 3.2.3.1: Richtlinien beurteilen

Beurteilen Sie die folgenden Aussagen. Ist die Aussage **Richtig** oder **Falsch**? Begründen Sie Ihre Antwort jeweils kurz in einem bis drei Sätzen.

Aussage A: Seriöse Banken und Institutionen fordern Kunden gelegentlich per E-Mail auf, ihr Passwort einzugeben, um die Identität bei Sicherheitsupdates zu bestätigen.

Aussage B: Beim Aufruf von Links sollte stets die exakte URL (Internetadresse) geprüft werden, da Angreifer häufig Buchstabendreher oder gefälschte Subdomains (Typosquatting) nutzen.

Aussage C: Ein Phishing-Angriff kann nur dann erfolgreich sein, wenn auf einem Computer keine Antiviren-Software installiert ist.

Aussage D: Das Scannen von QR-Codes auf Plakaten oder Parkuhren ist völlig risikofrei, da QR-Codes keine Viren oder Links enthalten können.

Literaturverzeichnis

[1] Bundesamt für Sicherheit in der Informationstechnik. *SMTP Smuggling ermöglicht Social Engineering per E-Mail (CSW-Nr. 2023-292569-1032)*. 2023.

[2] National Institute of Standards and Technology (NIST). *Digital Identity Guidelines (NIST SP 800-63)*. 2024.

Akronyme

MFA	Multi-Faktor-Authentisierung
NIST	National Institute of Standards and Technology

Glossar

Brute-Force-Angriff
Ein automatisierter Angriff, bei dem Programme alle möglichen Zeichenkombinationen systematisch durchprobieren.

Datenleck
Ein Vorfall, bei dem vertrauliche Daten unabsichtlich oder absichtlich veröffentlicht oder gestohlen werden.

Dictionary Attack (Wörterbuchangriff)
Ein gezielter Angriff, bei dem Listen mit gebräuchlichen Wörtern, Namen und bekannten Passwörtern systematisch getestet werden.

Entropie
Mass für die mathematische Stärke und Zufälligkeit bei der Generierung eines Passworts oder einer Passphrase, angegeben in Bit. Ein Bit beschreibt eine Ja/Nein-Entscheidung zur Halbierung des Suchraums bei automatisierten Angriffen. Bei echter Zufallsauswahl berechnet sich die Entropie aus dem Suchraum N:

$$E = \log_2(N)$$

Für Zeichen-Passwörter gilt $N = R^L$ (Zeichenvorrat R, Länge L), für Wort-Passphrasen gilt $N = W^L$ (Wörterbuchgrösse W, Länge L in Wörtern).

Klassisches Phishing
Eine Phishing-Methode, bei der Angreifer E-Mails oder Nachrichten an eine breite Masse von Personen senden, um an vertrauliche Informationen zu gelangen.

Passphrase
Eine längere Zeichenkette, oft bestehend aus mehreren zufälligen Wörtern, die als Passwort verwendet wird.

Passwort
Eine geheime Zeichenkette, die zur Authentisierung dient.

Passwort-Manager
Software zur sicheren Verwaltung und Generierung von Passwörtern.

Phishing
Eine Form des Social Engineering, bei der Angreifer versuchen, über gefälschte E-Mails, Nachrichten oder Webseiten an vertrauliche Daten zu gelangen.

PIN
Eine persönliche Identifikationsnummer, oft verwendet zur Authentifizierung von Nutzern.

Quishing
Eine Phishing-Methode, bei der manipulierte QR-Codes eingesetzt werden, um Opfer auf gefälschte Webseiten zu leiten.

Smishing Eine Phishing-Methode, bei der Angreifer über SMS versuchen, vertrauliche Informationen zu erlangen.

Social Engineering Die Manipulation von Personen durch psychologische Tricks, um an vertrauliche Informationen zu gelangen.

Spear-Phishing Ein gezielter Phishing-Angriff, der auf eine spezifische Person oder bestimmte Mitarbeiter zugeschnitten ist.

Suchraum Der gesamte mögliche Suchraum für ein Passwort oder einer Passphrase, bestehend aus allen möglichen (Zeichen)-Kombinationen.

Typosquatting Eine Technik, bei der Angreifer Domains registrieren, die ähnlich zu bekannten Webseiten sind, um Nutzer durch Tippfehler auf gefälschte Seiten zu locken.

Vishing Eine Phishing-Methode, bei der Angreifer telefonisch versuchen, vertrauliche Informationen zu erlangen.